Encryption and Key Management in AWS

Bill Shinn

Principal Security Solutions Architect

amazon web services

©2015, Amazon Web Services, Inc. or its affiliates. All rights reserved

Agenda

- **Client-Side Encryption:** You encrypt your data and manage your own keys
- **Server-Side Encryption:** AWS encrypts data and manages the keys for you
- **Key Management:**
  - On your own
  - AWS Key Management Service
  - With AWS partner solutions
  - Using AWS CloudHSM

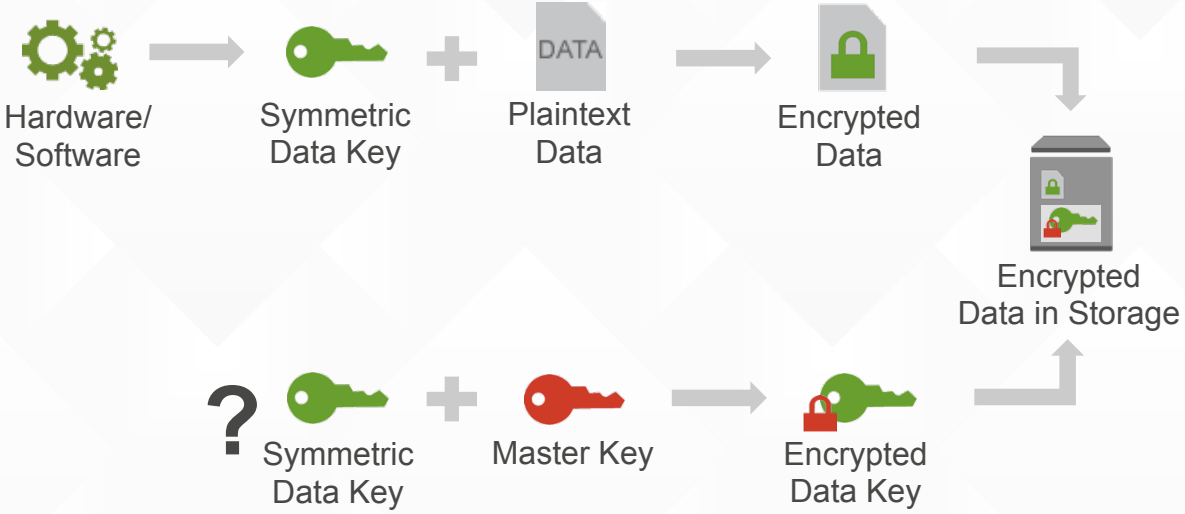
amazon web services

“Key” Questions to Consider

- Where are the keys stored?
- Where are the keys used?
- Who has access to the keys?

amazon
web services

Encryption Primer

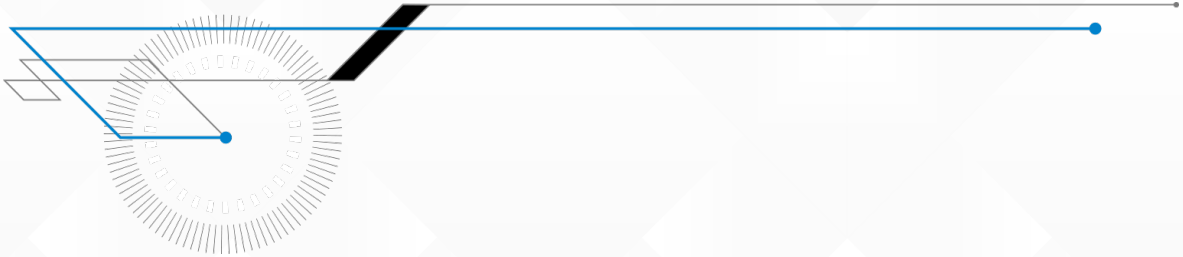


Key Hierarchy

amazon
web services

Client-Side Encryption

You encrypt your data and send to AWS service



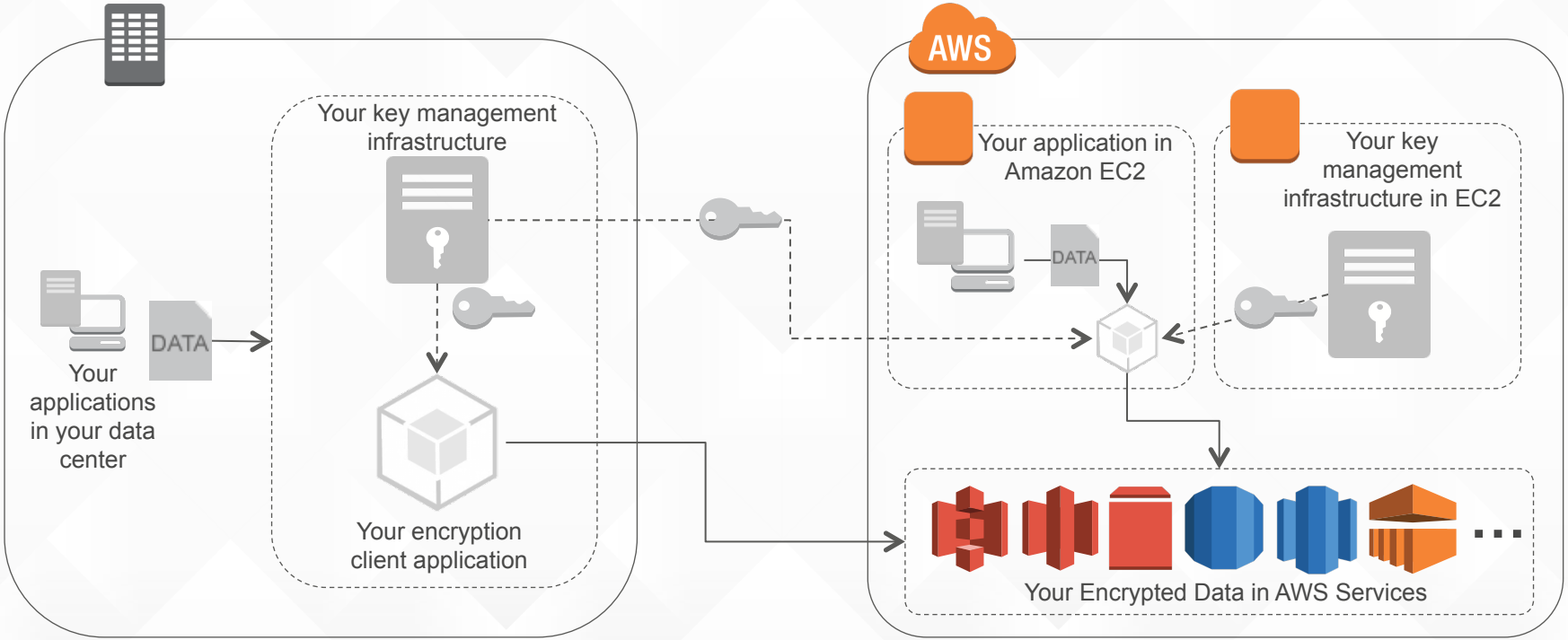
amazon web services

Client-Side Encryption

amazon web services

Client-Side Encryption

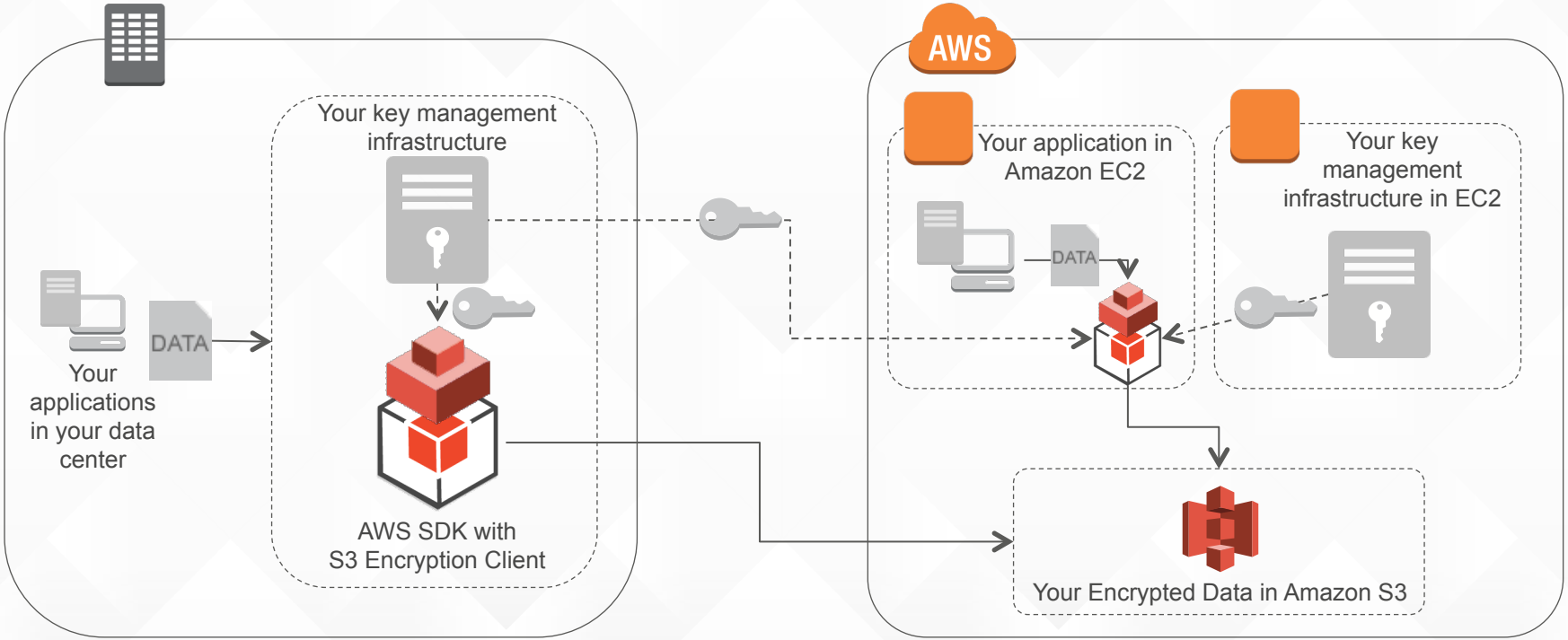
Overview



amazon web services

Client-Side Encryption with S3

Amazon S3 Encryption Client with AWS SDKs

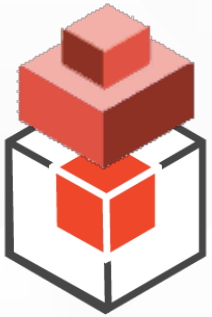


amazon web services

Client-Side Encryption

Amazon S3 Encryption Client with AWS SDKs

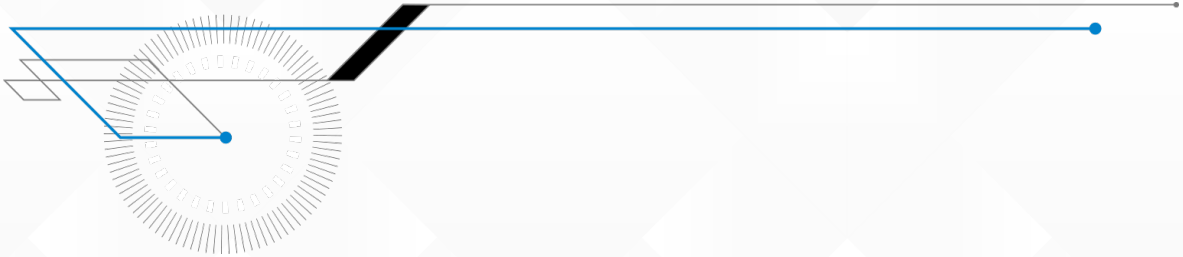
- Client creates dynamic 256-bit data key
- You supply the key-encrypting key
  - Symmetric or asymmetric (public portion)
- Uses JCE (can optionally configure crypto provider) to encrypt/decrypt data in your application
- Encrypted data key sent to S3; stored with encrypted data as object metadata or instruction file
- Available in Java, Ruby and .NET AWS SDKs



amazon web services

Server-Side Encryption

AWS services encrypt data for you



amazon web services

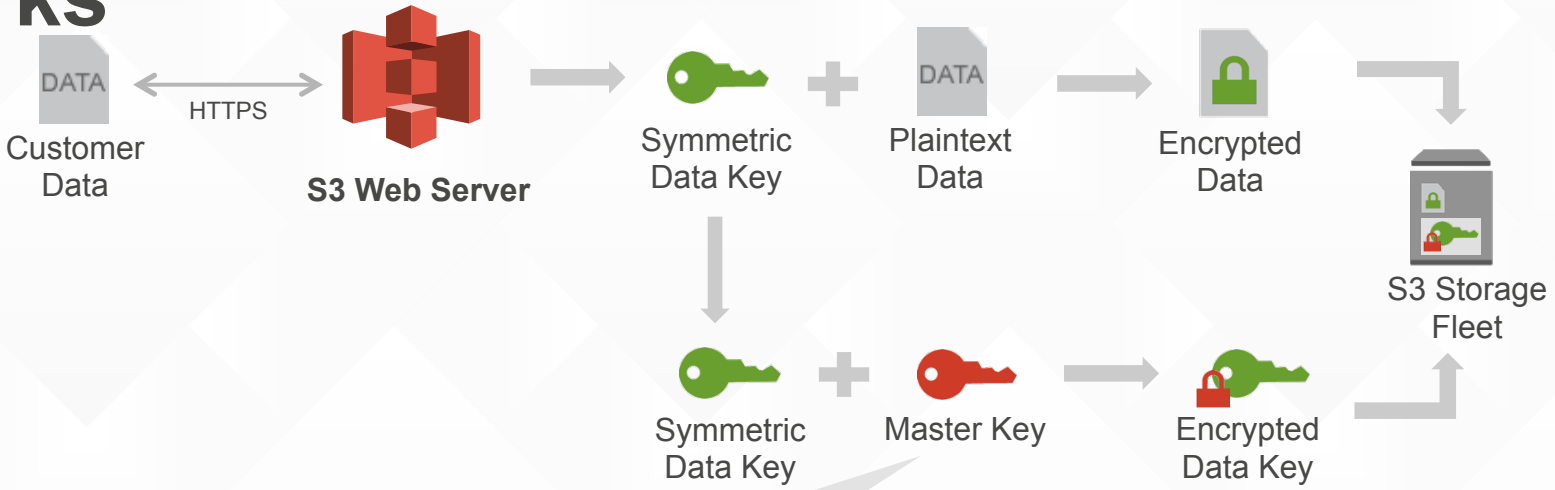
Server-Side Encryption

amazon web services

S3 Server Side Encryption

amazon web services

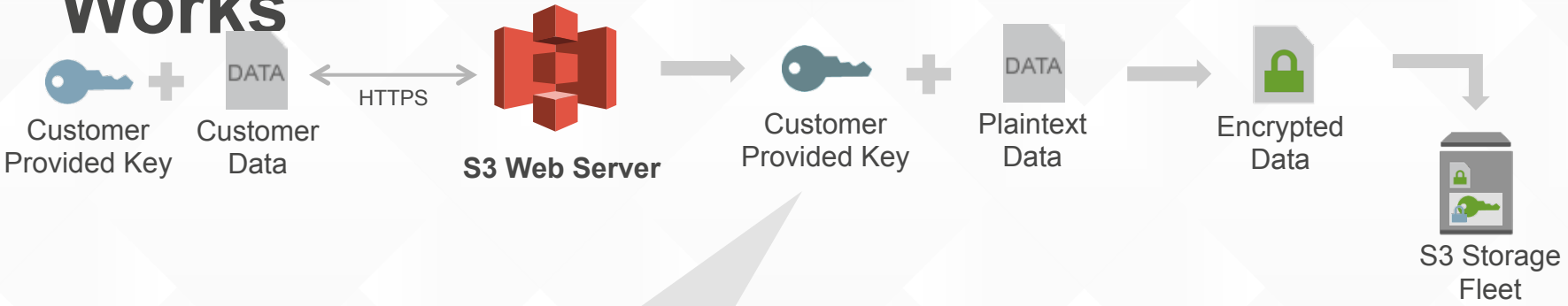
How S3 SSE with AWS Managed Keys Works



A master key managed by the S3 service and protected by systems internal to AWS

amazon web services

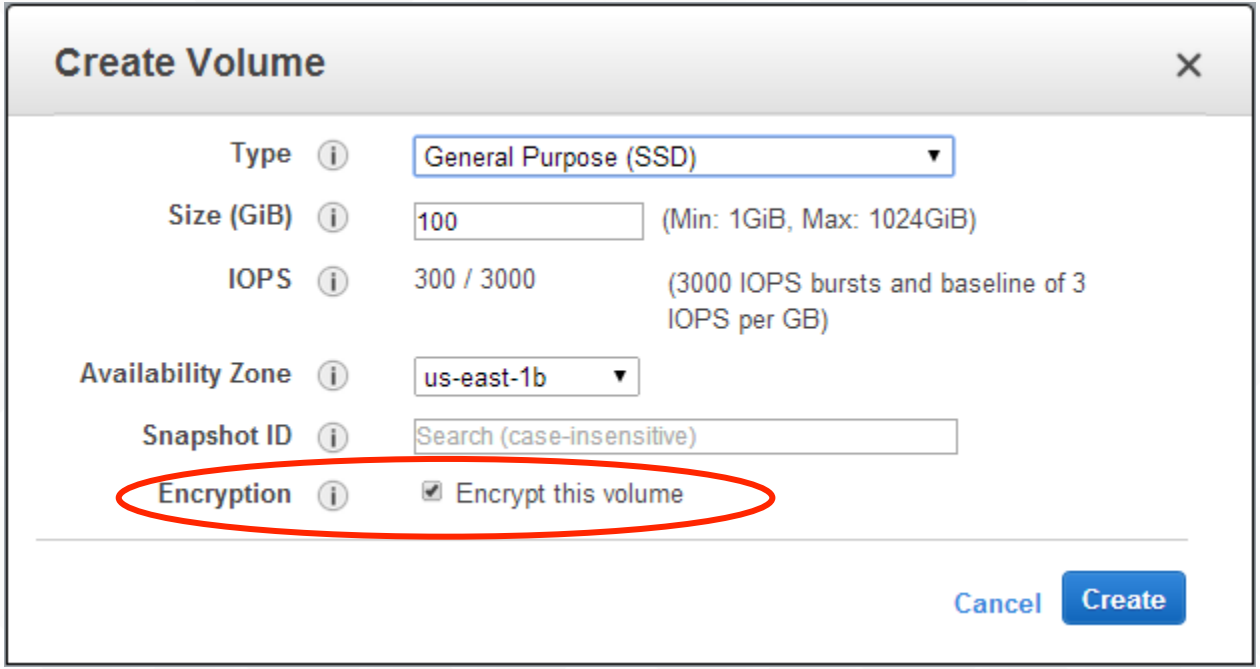
How S3 SSE with Customer Provided Keys Works



- **Key is used at S3 Webserver, then deleted**
- **Customer must provide same key when downloading to allow S3 to decrypt data**

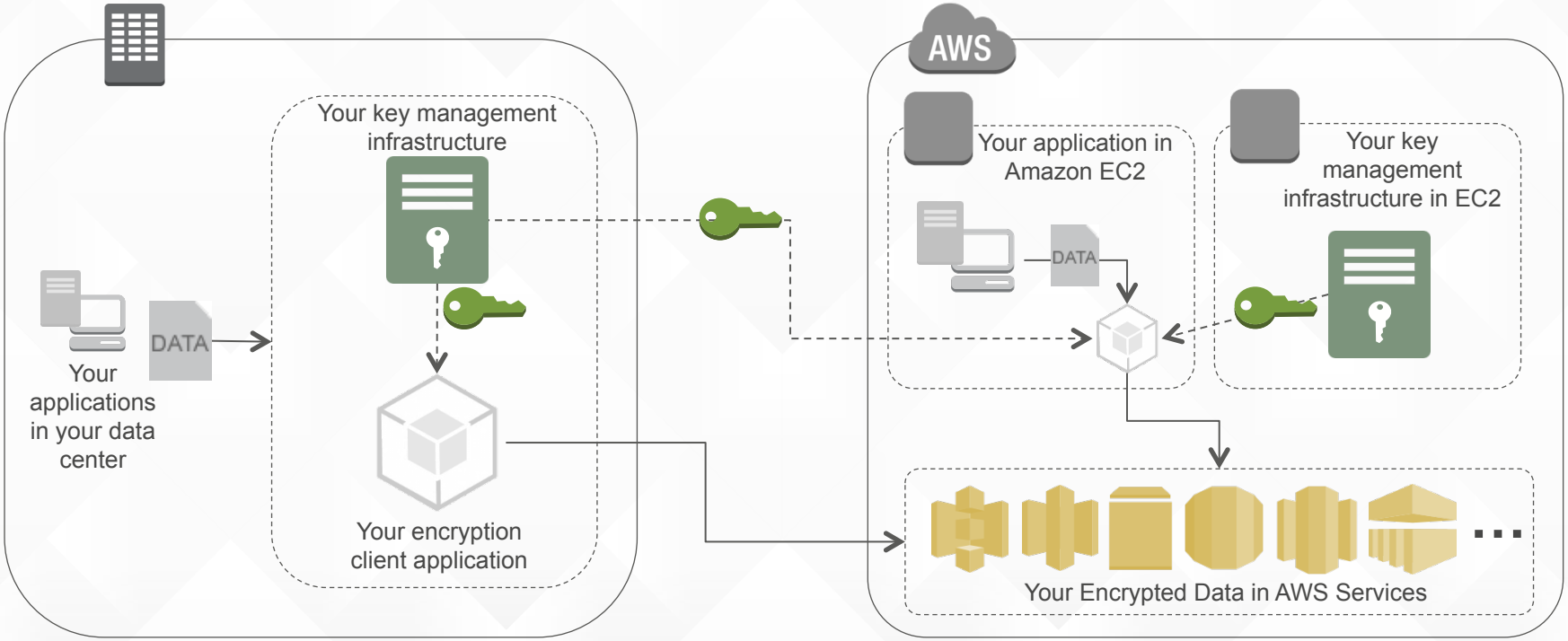
amazon web services

EBS Server Side Encryption



amazon web services

What About Key Management Infrastructure?



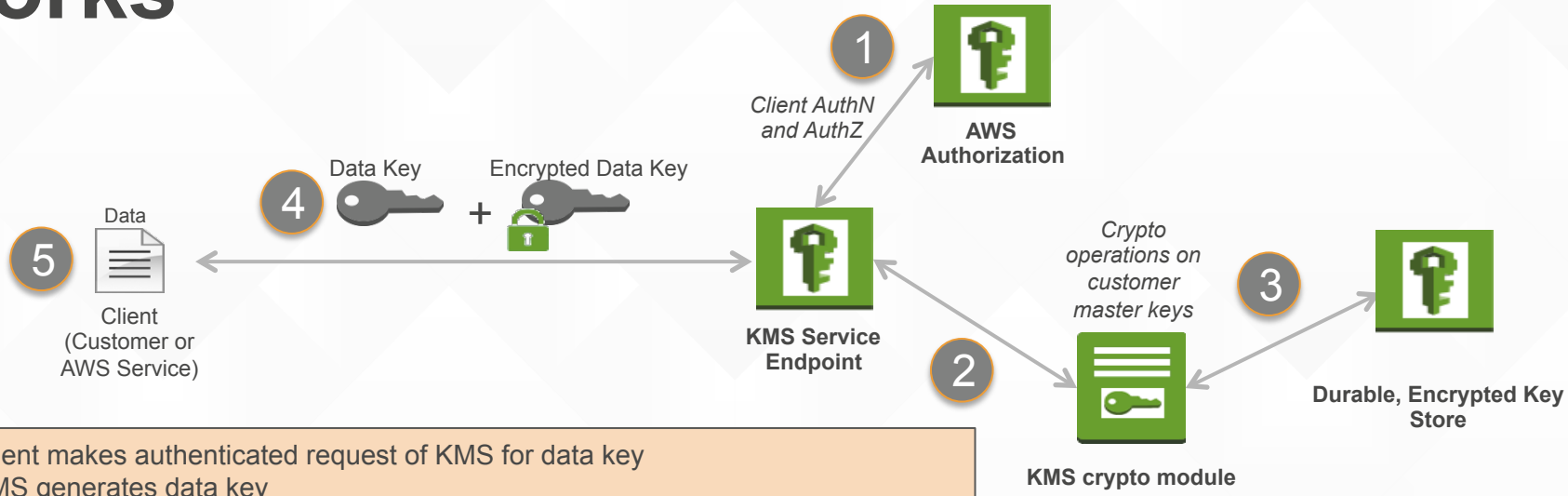
amazon web services

Introducing AWS Key Management Service

- A service that enables you to provision and use encryption keys to protect your data
- Allows you to create, use, and manage encryption keys from within…
  - Your own applications via AWS SDK
  - Supported AWS services (S3, EBS, RDS, Redshift)
- Available in all commercial regions

amazon web services

How AWS Key Management Service Works



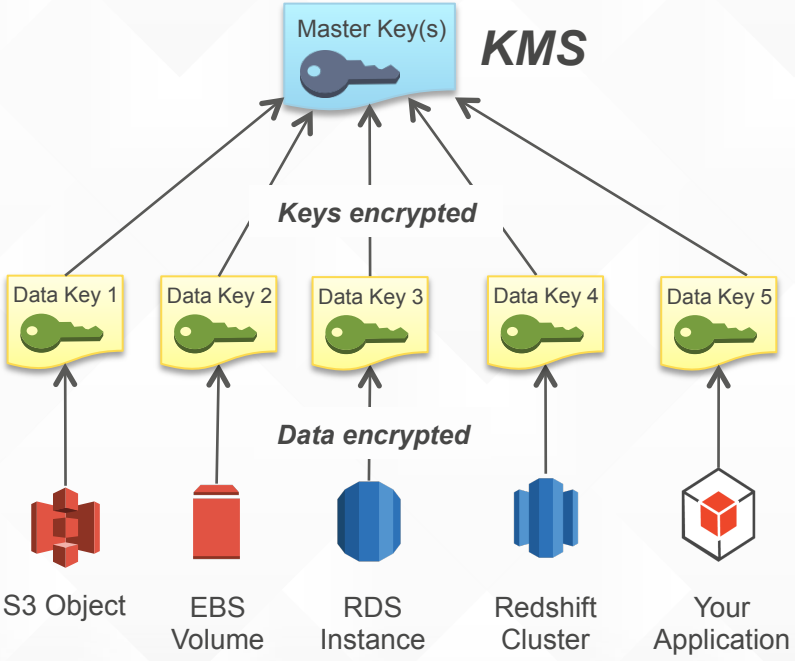
1. Client makes authenticated request of KMS for data key
2. KMS generates data key
3. KMS pulls encrypted customer master key from durable storage; decrypts in the KMS crypto module
4. KMS encrypts data key with named customer master key and returns plaintext data key and encrypted data key
5. Client uses data key to encrypt data, stores encrypted data key.

To decrypt: client submits encrypted data key to KMS for decryption; data key is needed to decrypt data

amazon web services

How AWS Services Integrate with KMS

- 2-tiered key hierarchy using envelope encryption
- Data keys encrypt customer data
- KMS master keys encrypt data keys
- Benefits:
  - Limits blast radius of compromised resources and their keys
  - Better performance
  - Easier to manage a small number of master keys than billions of resource keys



amazon web services

Creating and managing keys in KMS

Create Key | Key Actions | Region: US East (N. Virginia)

Filter: Only enabled keys | Search resource name or ID

Key ID	Alias	Description	Status
3485910s-6425-4a9a-8ebc-758492kduwj1	CriticalData	Protects data with critical data classification	Enabled
63h7sh1k-3h8x-mn22-11n6-mwnc8qb4h28x	HighlyConfidentialData	Protects data with highly confidential data classification	Enabled
2z88v2b4-h1mx-092g-iq53-12mxnt71b33r	ConfidentialData	Protects data with confidential data classification	Enabled
46xb83nc-883n-sh1a-k3nc-uwjsnbd73f19a	ApplicationFoo	Protects data for the foo application	Enabled
62bcn1ms-2mms-333t-8792-zb1n3m60wkcb	ApplicationBar	Protects data for the bar application	Disabled
6a25a0d2-6425-0569-7wt3-6304284t8l1	aws/ebs	Default master key that protects my EBS volumes when no other key is defined	Enabled
34g0hh81-9999-4a9a-8ebc-gkd04gj104lsg	aws/rds	Default master key that protects my RDS database volumes when no other key is defined	Enabled
203jdap2-6425-4a9a-0000-330498djgla1	aws/redshift	Default master key that protects my Redshift clusters when no other key is defined	Enabled
7e262fx4-4h6s-3hrf-73y6-shj3kry72g46s	aws/s3	Default master key that protects my S3 objects when no other key is defined	Enabled

amazon web services

Amazon S3 server-side encryption with KMS

☑ Use Server Side Encryption Learn more

○ **Use the S3 service master key**

Uses the master key maintained by S3, which will allow anyone with access to this object to be able to decrypt it.

◉ **Use an Amazon KMS master key**

Uses a master key maintained by the Amazon Key Management Service, which provides a separate set of permissions for use of the key as well as auditing of key usage.

Master Key: my_custom_kms_key ▼

Description: The description that the customer entered when they created the key.

Account: This account (123456789)

Key ID: 87654321-4321-4321-4321-987654321XYZ

< Select Files | Set Permissions > | Start Upload | Cancel

amazon web services

Amazon EBS encryption with KMS

Encryption ☑ Encrypt this volume ⓘ

Master Key MyKeyAlias1 ⓘ

Key details

Key ID 1a2b3c4e5g6h7i8j9k

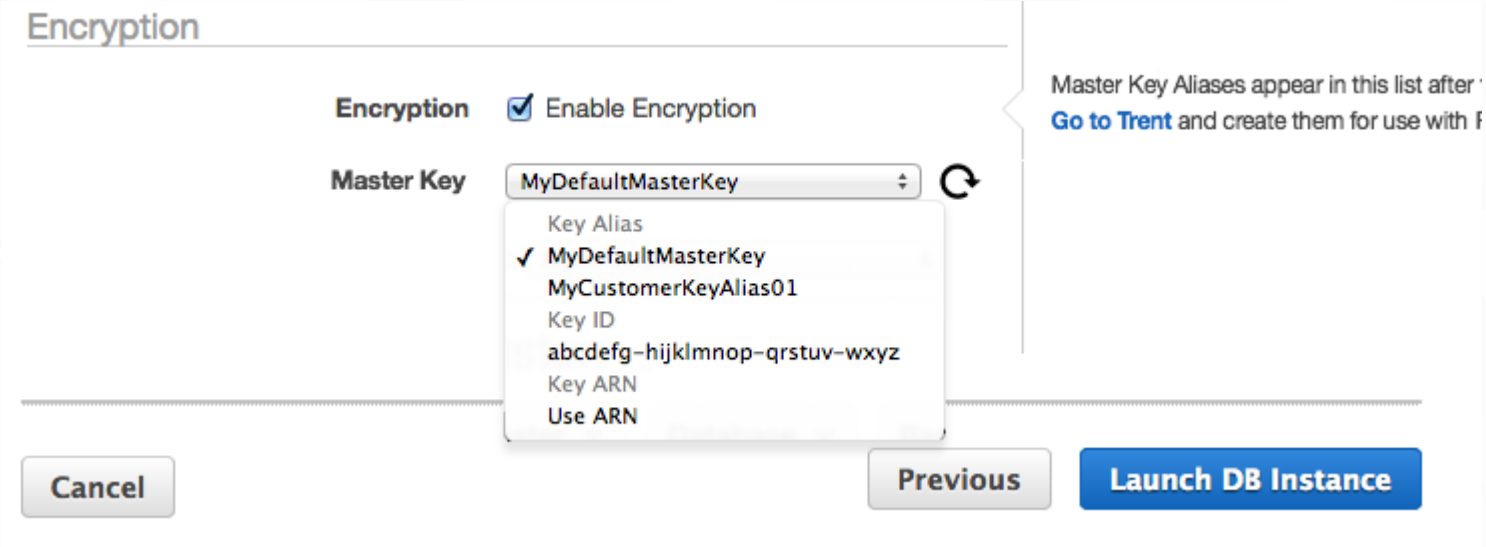
Alias My Key Alias 1

Description Lorum ipsum dolo asit amet..

Cancel **Create**

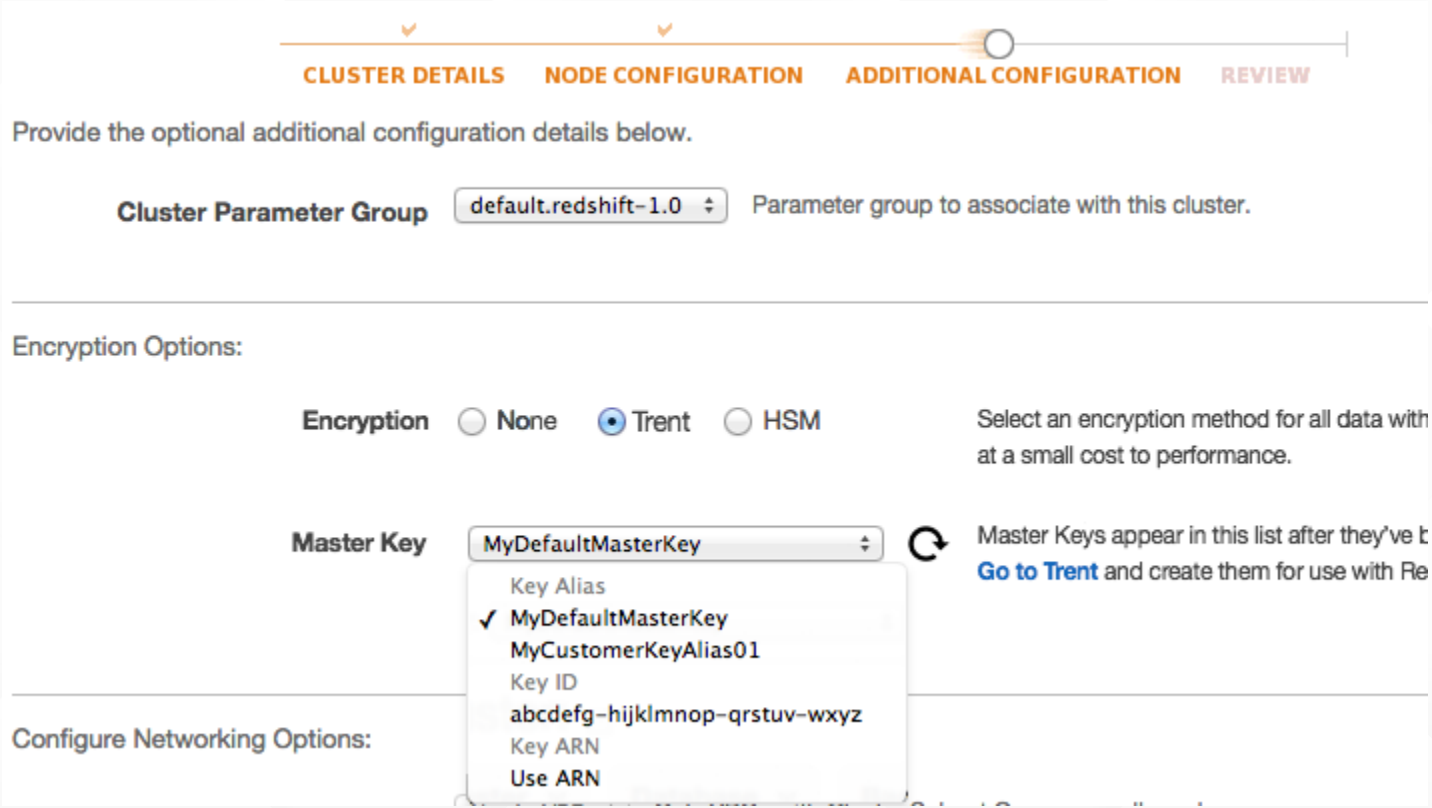
amazon web services

Amazon RDS encryption with KMS



amazon web services

Amazon Redshift encryption with KMS



amazon web services

KMS gives you control

You define who can…

- Create a master key
- Use a master key
- Create and export a data key that is encrypted by a master key
- Enable/disable master keys
- Audit use of master keys in AWS CloudTrail

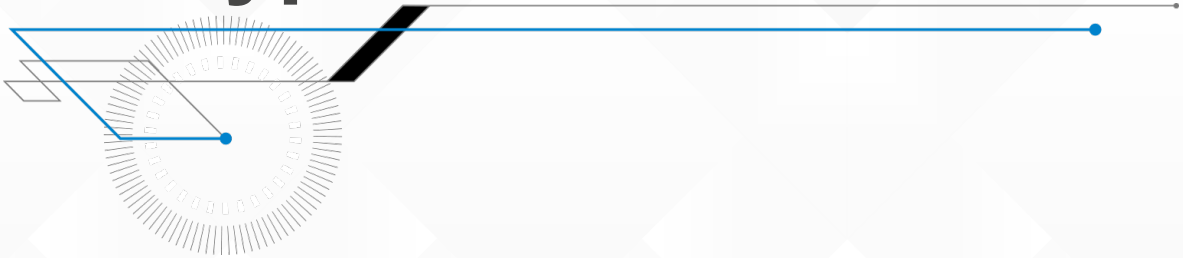
amazon web services

KMS secures your keys

- Plaintext keys are never stored in persistent memory on runtime systems
- Separation of duties
  - AWS service team operators (S3, EBS, RDS) can’t access KMS hosts that use master keys and KMS operators can’t access service team hosts that use data keys
- Multi-party controls
  - Normal operations require signatures from two or more KMS operators on any API calls to an active host processing customer keys
- Verified claims in SOC1 and public white papers

amazon web services

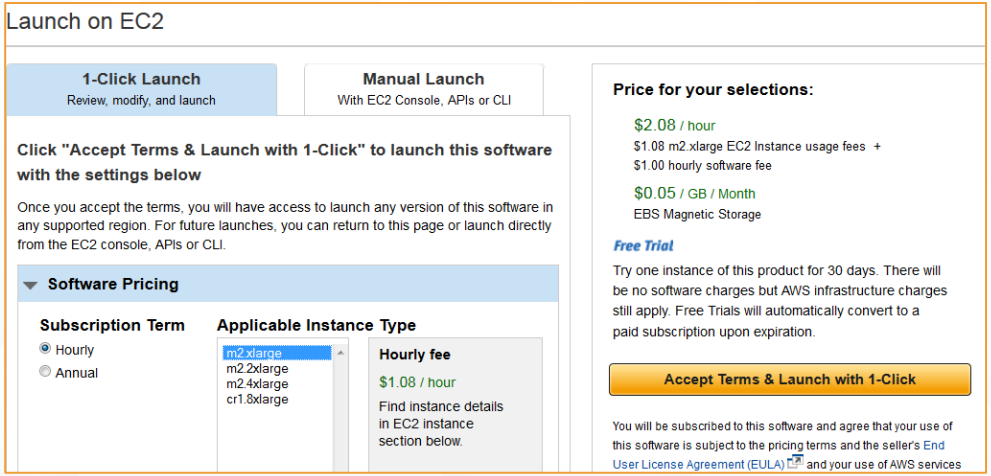
Alternate key management and encryption solutions



amazon web services

AWS Marketplace for Security

- Browse, test and buy security software
- Pay-by-the-hour, monthly, or annual
- Software fees added to AWS bill
- Bring Your Own License



Key management and client-side encryption using an AWS partner solution

Solutions integrated with EC2, EBS, S3, and RDS

amazon web services

Encryption and Key Management with AWS CloudHSM

amazon web services

HSM – Hardware Security Module

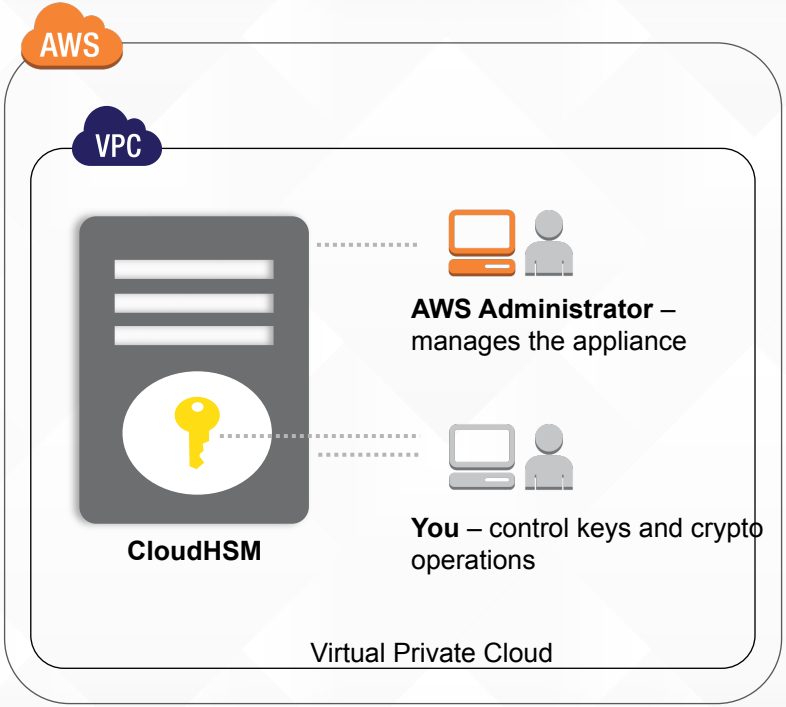
- Hardware device for crypto ops and key storage
- Strong protection of private keys
  - Physical device control does not grant access to the keys
  - Security officer controls access to the keys
  - Appliance administrator has no access to the keys
- Certified by 3rd parties to comply with security standards

HSM

amazon web services

AWS CloudHSM

- You receive dedicated access to HSM appliances
- HSMs are located in AWS datacenters
- Managed & monitored by AWS
- Only you have access to your keys and operations on the keys
- HSMs are inside your VPC – isolated from the rest of the network
- Uses SafeNet Luna SA HSM appliances



amazon web services

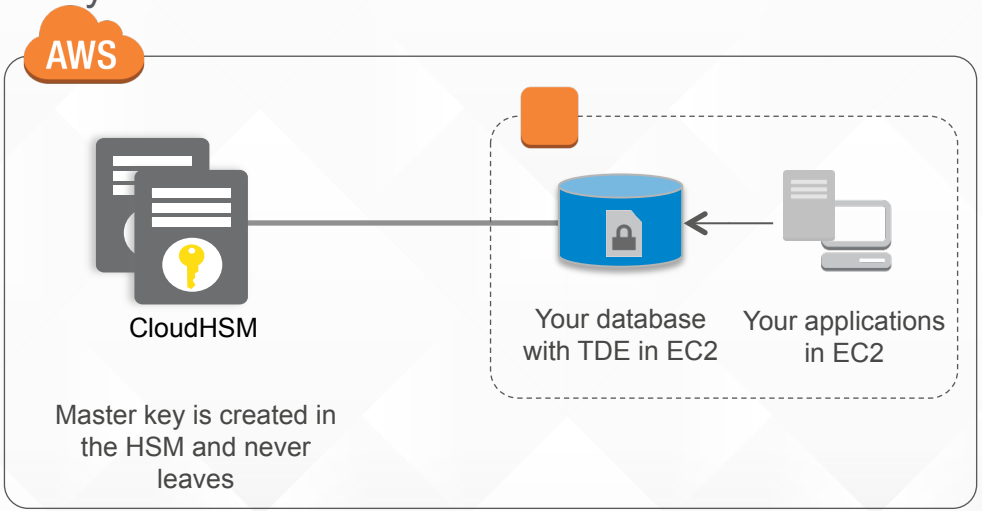
AWS CloudHSM

- Available in five regions worldwide
  - US East (N. Virginia), US West (Oregon), EU (Ireland), EU (Frankfurt) and Asia Pacific (Sydney) (and more on the way)
- Easy to get started
  - AWS CloudFormation template
  - Application notes to help integrate with 3rd party software
- Compliance
  - Included in AWS PCI DSS and Service Organization Control (SOC) compliance packages

amazon web services

Database Encryption

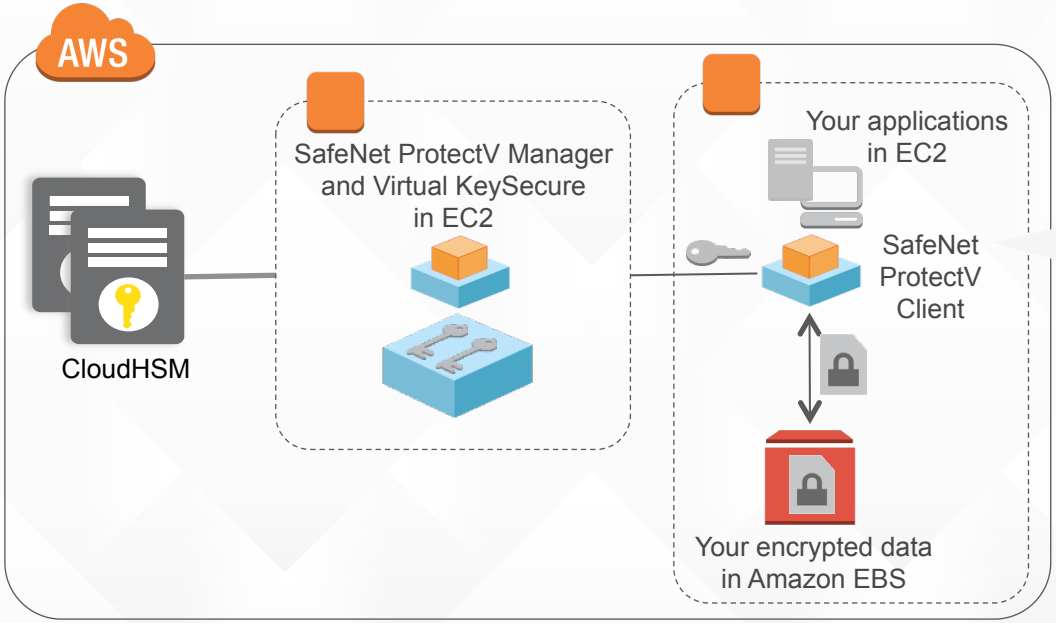
- Customer-managed databases in EC2
  - Oracle Database 11g TDE (Transparent Data Encryption)
  - Microsoft SQL Server 2008 and 2012 TDE
  - Master key in CloudHSM



amazon web services

EBS Volume Encryption

- SafeNet ProtectV with Virtual KeySecure
- CloudHSM stores the master key

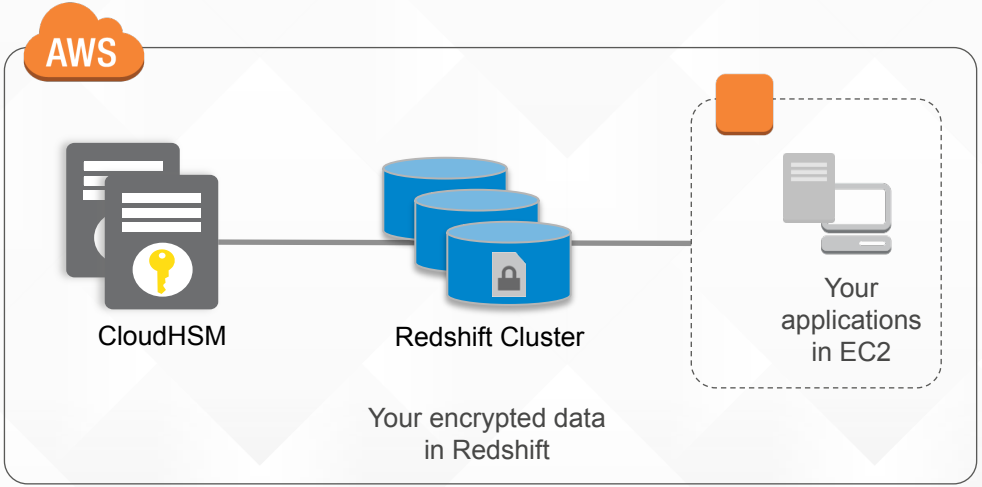


ProtectV Client
- Encrypts I/O from EC2 instances to EBS volumes
- Includes pre-boot authentication

amazon web services

Redshift Encryption

- Cluster master key in on-premises SafeNet HSM or CloudHSM
- No special client software required



amazon web services

CloudHSM: Custom Software Applications

An architectural building block to help you secure your own applications

- Use standard libraries, with backend HSM rather than software-based crypto
  - PKCS#11, JCA/JCE, Microsoft CAPI/CNG
- Code examples and details in the CloudHSM Getting Started Guide make it easier to get started (aws.amazon.com/cloudhsm)

amazon web services

Comparing CloudHSM with KMS

AWS CloudHSM

- Dedicated access to HSM that complies with government standards (FIPS, CC)
- You control your keys and the application software that uses them

AWS KMS

- Builds on the strong protections of an HSM foundation
- Highly available and durable key storage, management, and auditing solution
- Easily encrypt your data across AWS services and within your own applications based on policies you define

amazon web services

Comparison of Key Management Options

	On-Premises HSM	AWS CloudHSM	AWS Key Management Service
Where keys are generated and stored	Your network	AWS	AWS
Where keys are used	Your network or your EC2 instance	AWS + your network	AWS
How to use keys	Customer code	Customer code + Safenet APIs	Management Console, AWS SDKs
Performance/Scale/HA responsibility	You	You	AWS
Integration with AWS services?	No	Redshift	Yes
Price	$$$$	$$	$
Who controls access to keys	Only You	Only You	You + AWS

Resources

- AWS Key Management Service
  - https://aws.amazon.com/kms
- AWS CloudHSM
  - https://aws.amazon.com/cloudhsm/
- Whitepaper on data-at-rest encryption and key management in AWS
  - https://aws.amazon.com/whitepapers/
- S3 Encryption Client
  - http://aws.amazon.com/articles/2850096021478074
- AWS Partner Network
  - http://www.aws-partner-directory.com/
- AWS Security Blog
  - http://blogs.aws.amazon.com/security

amazon web services